Breaking VNC Clients with Evil Servers

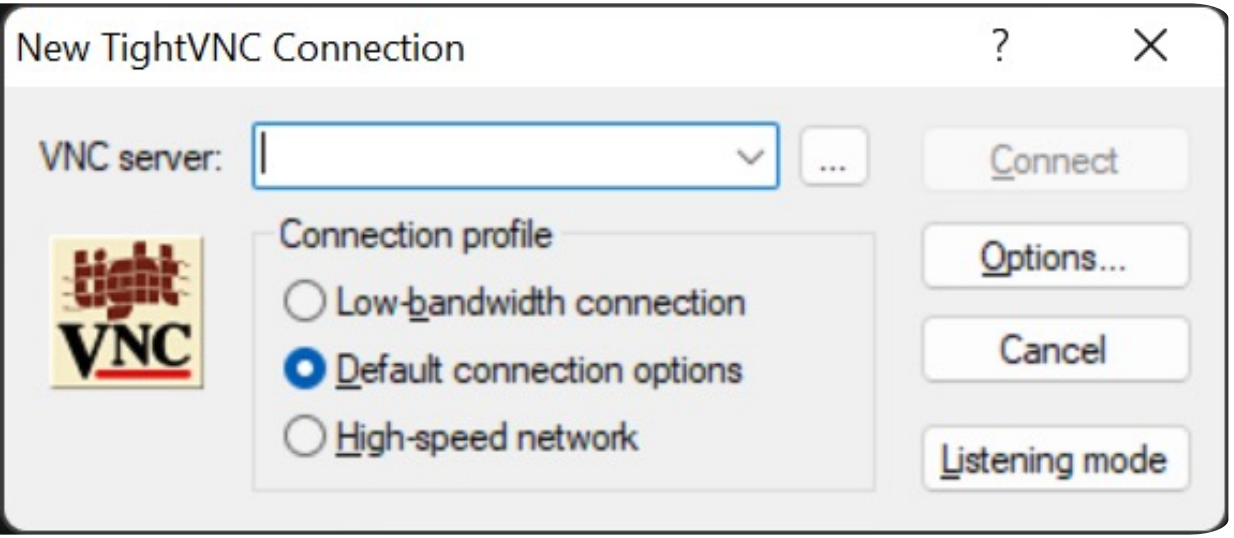
Eugene Lim

@spaceraccoonsec

spaceraccoon.dev

Disclaimer

This is actually a starter guide for fellow vulnerability research n00bs, not a deep dive into VNC



Sometimes you need to connect to a desktop remotely…

Virtual Network Computing (VNC) is just one of many remote desktop protocols.

VNC

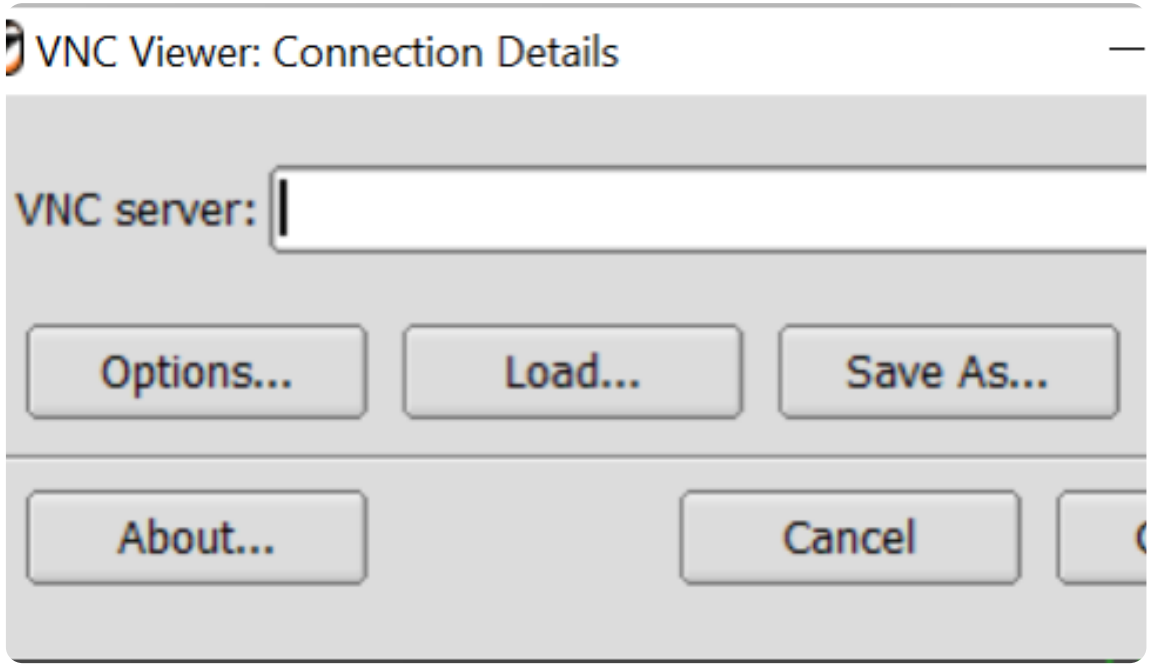
RDP

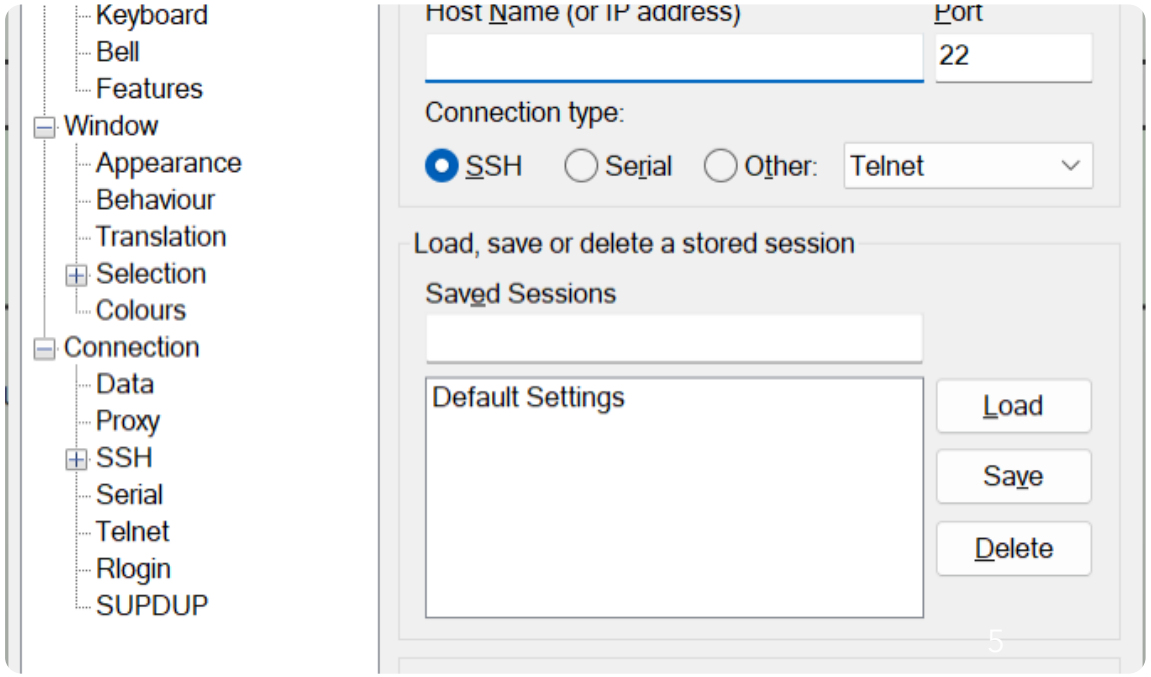
ESXi

Citrix

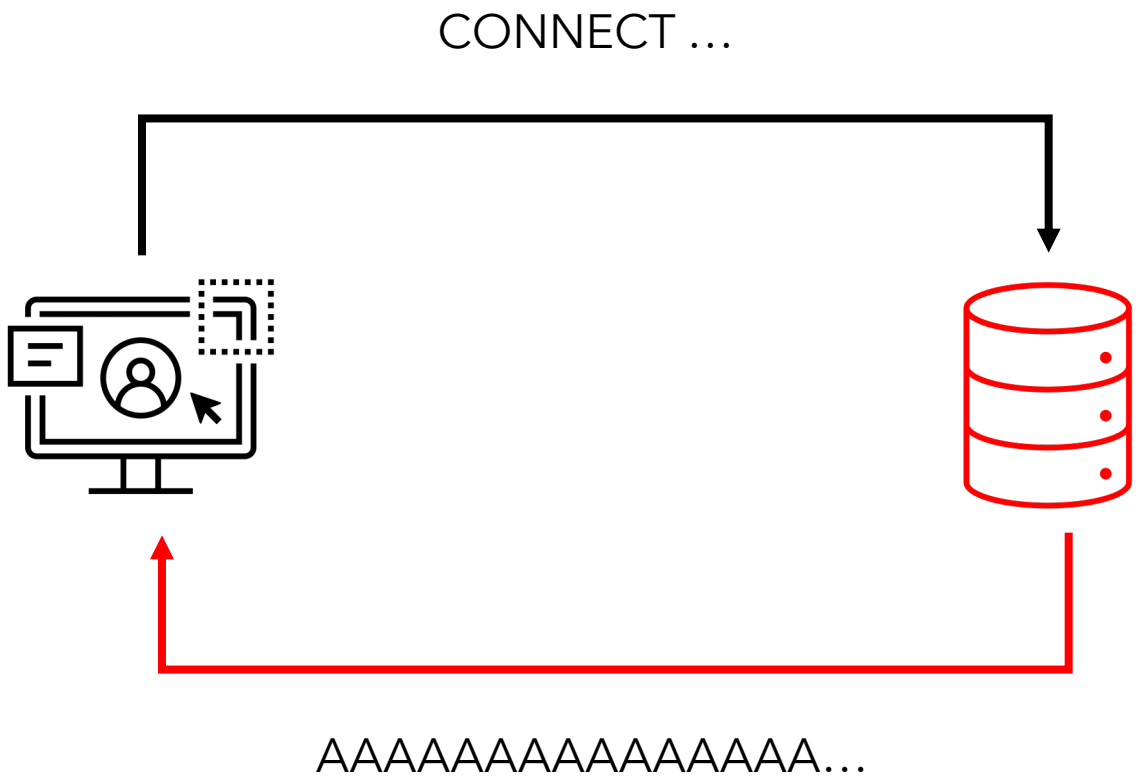
SPICE

Practicing vulnerability research and code review on open-source remote desktop clients.





Why clients? It's an interesting attack vector.



I created a simple plan of attack.

Read specification

Source code review

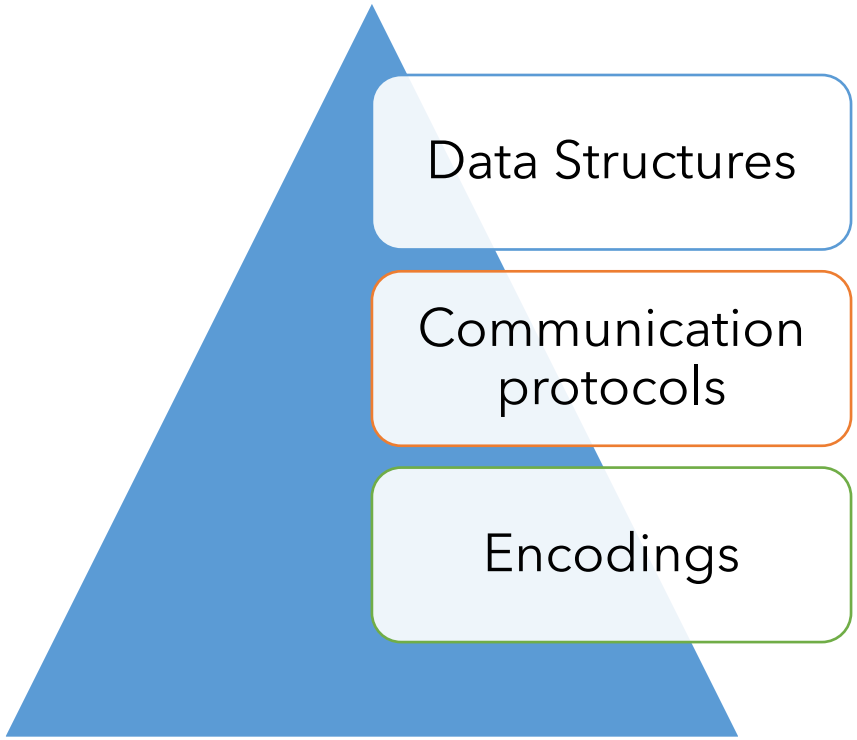
Write evil server

Run test cases

???

Profit

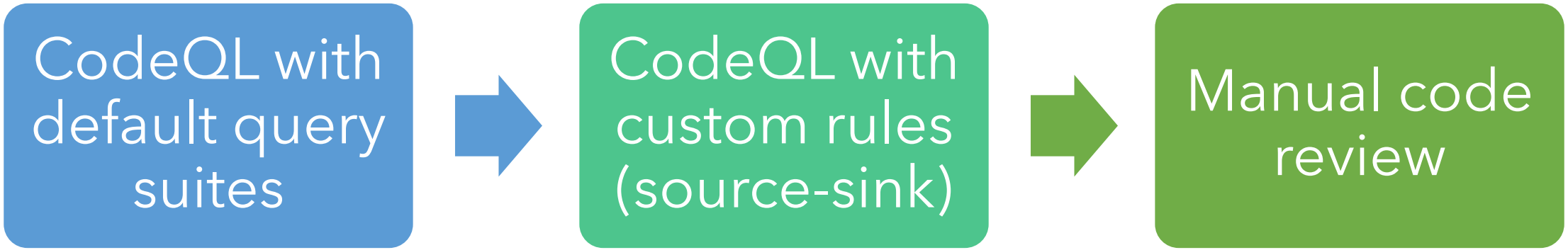
RFC6143 “The Remote Framebuffer Protocol” describes a short and simple protocol (39 pages).



No. of bytes	Type [Value]	Description
4	U32	length
length	U8 array	zlibData

Tag-Length-Value (TLV) schemes are a great source of buffer overflow bugs.

After generating possible exploit scenarios, run a code review sieve on multiple targets.



eQL Query Results ×

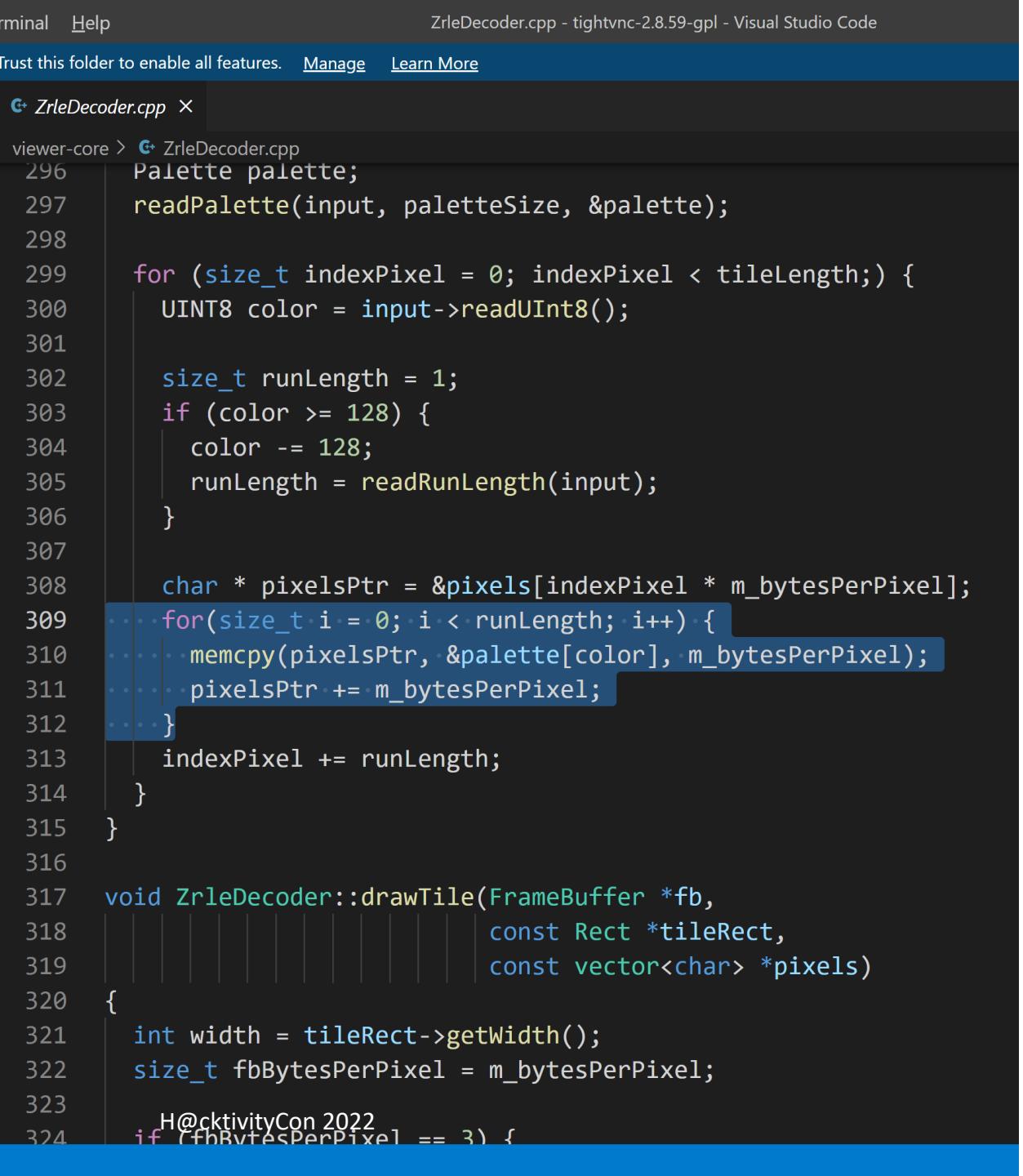
t ▾ 10 results

var	location
gp_offset	file://:0:0:0:0
fp_offset	file://:0:0:0:0
overflow_arg_area	file://:0:0:0:0
reg_save_area	file://:0:0:0:0
argc	file:///home/cyber/code.c:1:14:1:17
argv	file:///home/cyber/code.c:1:27:1:30
size1	file:///home/cyber/code.c:3:9:3:13
size2	file:///home/cyber/code.c:4:9:4:13
dst	file:///home/cyber/code.c:6:11:6:13
src	file:///home/cyber/code.c:7:11:7:13

The VS Code plugin makes CodeQL more user-friendly.

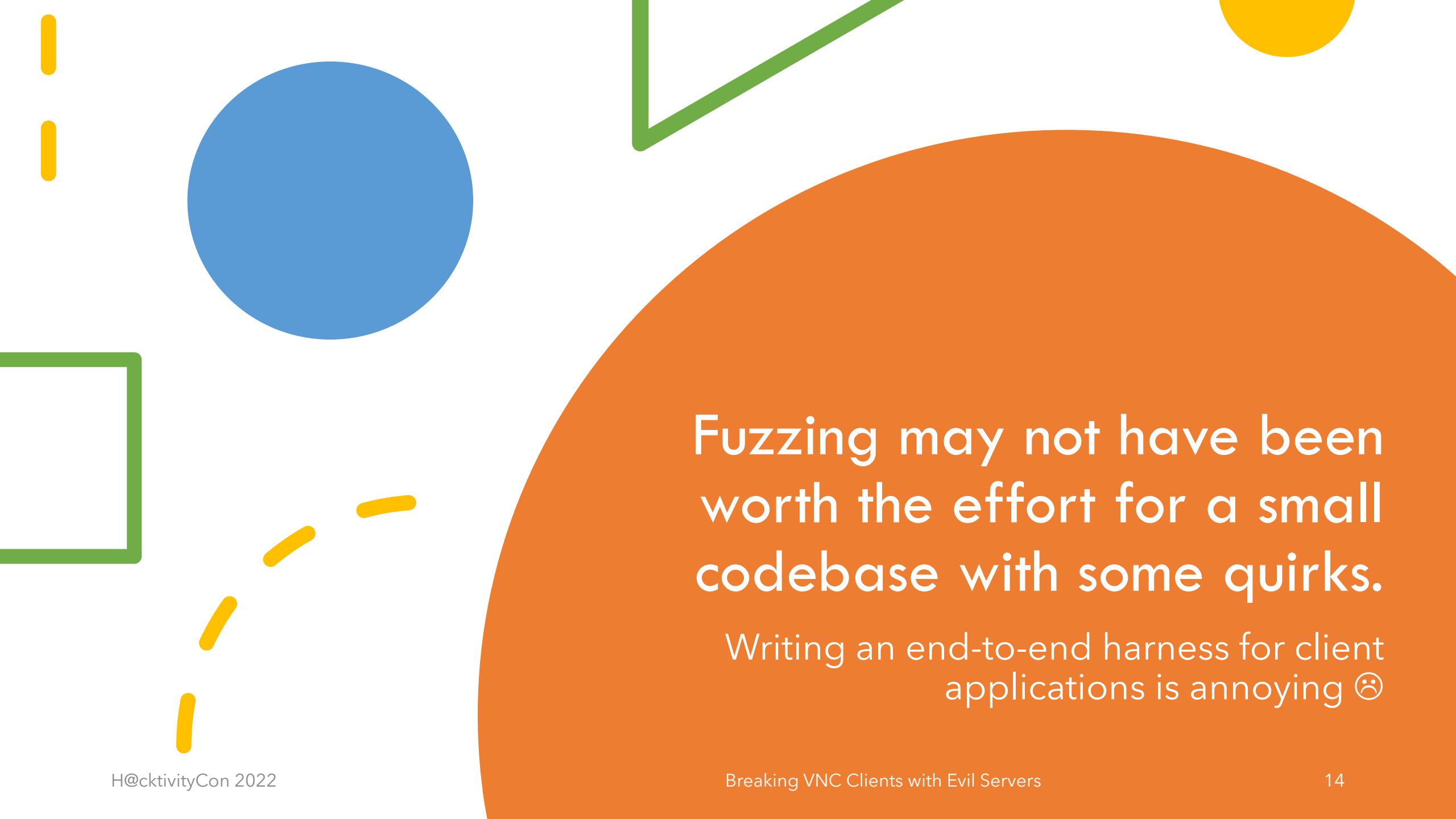
Craft a custom source-sink CodeQL query and step through the data flows.

```
import cpp
import semmle.code.cpp.dataflow.TaintTracking


class StreamToMemcpyConfiguration extends DataFlow::Configuration {
  StreamToMemcpyConfiguration() { this = "StreamToMemcpyConfiguration" }

  override predicate isSource(DataFlow::Node source) {
    exists (Function recv |
      source.asExpr().(FunctionCall).getTarget() = recv and
      (
        recv.hasQualifiedName("rdp_recv") or
        recv.hasQualifiedName("tcp_recv") or
        recv.hasQualifiedName("iso_recv")
      )
    )
  }

  override predicate isSink(DataFlow::Node sink) {
    exists (FunctionCall fc |
      sink.asExpr() = fc.getArgument(1) and
      fc.getTarget().hasQualifiedName("memcpy")
    )
  }
}

from Expr rdpRecv, Expr memcpy, StreamToMemcpyConfiguration config
where config.hasFlow(DataFlow::exprNode(rdpRecv), DataFlow::exprNode(memcpy))
select memcpy, "This 'memcpy' uses data from $@ as src.",
  rdpRecv, "call to 'rdp_recv'"
```



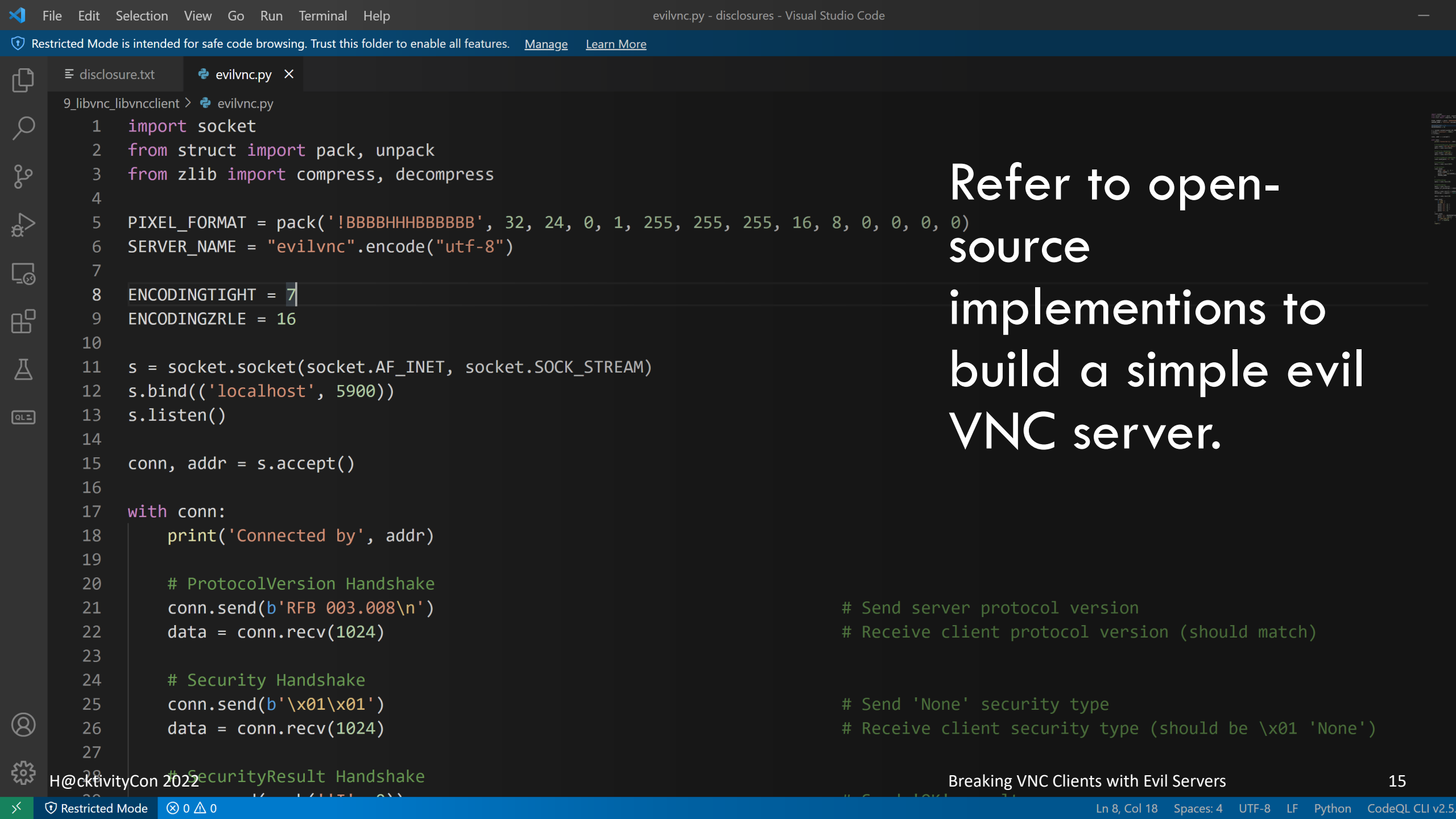
CodeQL identifies problem areas but don't avoid manual code review

- bufferSize argument in memcpy ✅
- runLength number of loops ❌
- Eventually overflows buffer and overwrites EIP
- Not detected by standard CodeQL rules



Fuzzing may not have been worth the effort for a small codebase with some quirks.

Writing an end-to-end harness for client applications is annoying ☹



Refer to open-source implementions to build a simple evil VNC server.

C:\Users\Eugene\Desktop\tvnviewer.exe - WinDbg:10.0.19041.685 X86

File Edit View Debug Window Help

Command

```
ModLoad: 72d80000 72de9000   C:\WINDOWS\SysWOW64\ntmarta.dll
ModLoad: 70860000 7093b000   C:\WINDOWS\SysWOW64\wintypes.dll
ModLoad: 02960000 02a3b000   C:\WINDOWS\SysWOW64\wintypes.dll
ModLoad: 6dfe0000 6e074000   C:\WINDOWS\SysWOW64\TextShaping.dll
ModLoad: 70ce0000 70cf1000   C:\WINDOWS\SysWOW64\napinsp.dll
ModLoad: 70cc0000 70cd6000   C:\WINDOWS\SysWOW64\pnrpnsp.dll
ModLoad: 70cb0000 70cc0000   C:\WINDOWS\SysWOW64\wshbth.dll
ModLoad: 70c90000 70ca6000   C:\WINDOWS\SysWOW64\NLAapi.dll
ModLoad: 75000000 75032000   C:\WINDOWS\SysWOW64\IPHLPAPI.DLL
ModLoad: 73520000 73572000   C:\WINDOWS\SysWOW64\mswsock.dll
ModLoad: 74f60000 74ff2000   C:\WINDOWS\SysWOW64\DNSAPI.dll
ModLoad: 76930000 76937000   C:\WINDOWS\SysWOW64\NSI.dll
ModLoad: 70c80000 70c8e000   C:\WINDOWS\SysWOW64\winrnr.dll
ModLoad: 707a0000 707f8000   C:\WINDOWS\SysWOW64\fwpuclnt.dll
ModLoad: 76c90000 76ca9000   C:\WINDOWS\SysWOW64\bcrypt.dll
ModLoad: 70800000 70808000   C:\Windows\SysWOW64\rasadhlp.dll
HEAP[tvnviewer.exe]: Invalid address specified to RtlFreeHeap( 02610000, 03566D98 )
(4a30.5f08): Break instruction exception - code 80000003 (first chance)
eax=00425000 ebx=03566d90 ecx=009b46a4 edx=02a9f331 esi=02610000 edi=00000000
eip=772aad7a esp=02a9f4a0 ebp=02a9f4b4 iopl=0         nv up ei pl nz na po nc
cs=0023  ss=002b  ds=002b  es=002b  fs=0053  gs=002b             efl=00000202
ntdll!RtlpValidateHeapEntry+0x6383b:
772aad7a cc              int     3
0:005> g
HEAP[tvnviewer.exe]: Heap block at 035666B8 modified at 035666C3 past requested size of 3
(4a30.5f08): Break instruction exception - code 80000003 (first chance)
eax=00425000 ebx=035666c3 ecx=009b46a4 edx=02a9f371 esi=035666b8 edi=00000003
eip=772fd7d2 esp=02a9f4e0 ebp=02a9f4f0 iopl=0         nv up ei pl nz na po nc
cs=0023  ss=002b  ds=002b  es=002b  fs=0053  gs=002b             efl=00000202
ntdll!RtlpCheckBusyBlockTail+0x1a6:
772fd7d2 cc              int     3
0:005> g
HEAP[tvnviewer.exe]: Invalid address specified to RtlFreeHeap( 02610000, 035666C0 )
(4a30.5f08): Break instruction exception - code 80000003 (first chance)
eax=00425000 ebx=035666b8 ecx=009b46a4 edx=02a9f391 esi=02610000 edi=00000000
eip=772aad7a esp=02a9f4f8 ebp=02a9f50c iopl=0         nv up ei pl nz na po nc
cs=0023  ss=002b  ds=002b  es=002b  fs=0053  gs=002b             efl=00000202
ntdll!RtlpValidateHeapEntry+0x6383b:
772aad7a cc              int     3
0:005> g
HEAP[tvnviewer.exe]: Invalid address specified to RtlFreeHeap( 02610000, 03567068 )
(4a30.5f08): Break instruction exception - code 80000003 (first chance)
eax=00425000 ebx=03567060 ecx=009b46a4 edx=02a9f391 esi=02610000 edi=00000000
eip=772aad7a esp=02a9f4f8 ebp=02a9f50c iopl=0         nv up ei pl nz na po nc
cs=0023  ss=002b  ds=002b  es=002b  fs=0053  gs=002b             efl=00000202
ntdll!RtlpValidateHeapEntry+0x6383b:
772aad7a cc              int     3
0:005> g
(4a30.2434): Access violation - code c0000005 (first chance)
First chance exceptions are reported before any exception handling.
This exception may be expected and handled.
eax=41414141 ebx=035981a8 ecx=03566f98 edx=41414141 esi=035981b0 edi=02610000
eip=772683dc esp=0345f15c ebp=0345f2fc iopl=0         nv up ei ng nz na po cy
cs=0023  ss=002b  ds=002b  es=002b  fs=0053  gs=002b             efl=00010283
ntdll!RtlpAllocateHeap+0x13fc:
772683dc 8b10            mov     edx,dword ptr [eax]  ds:002b:41414141=????????
0:004> g
(4a30.5f08): C++ EH exception - code e06d7363 (first chance)
(4a30.2434): C++ EH exception - code e06d7363 (first chance)
(4a30.2434): C++ EH exception - code e06d7363 (!!! second chance !!!)
eax=0345f610 ebx=00000000 ecx=00000003 edx=00000000 esi=001a6b28 edi=00000001
eip=75e8b4b2 esp=0345f610 ebp=0345f668 iopl=0         nv up ei pl nz ac po nc
cs=0023  ss=002b  ds=002b  es=002b  fs=0053  gs=002b             efl=00000212
KERNELBASE!RaiseException+0x62:
75e8b4b2 8b4c2454        mov     ecx,dword ptr [esp+54h] ss:002b:0345f664=a3ec1ca3
0:004> g
WARNING: Continuing a non-continuable exception
(4a30.2434): Break instruction exception - code 80000003 (first chance)
eax=0345f610 ebx=00000000 ecx=a0a9eab3 edx=00000000 esi=001a6b28 edi=00000001
eip=0015c905 esp=0345f6b0 ebp=0345f6bc iopl=0         nv up ei pl zr na pe nc
cs=0023  ss=002b  ds=002b  es=002b  fs=0053  gs=002b             efl=00000246
tvnviewer+0x6c905:
0015c905 cc              int     3
0:004> g
(4a30.5f08): Access violation - code c0000005 (first chance)
First chance exceptions are reported before any exception handling.
This exception may be expected and handled.
eax=41414141 ebx=00146149 ecx=eb24b6c8 edx=00000000 esi=02a9f240 edi=02a9f9b0
eip=0015d1f0 esp=02a9efe4 ebp=02a9efe4 iopl=0         nv up ei pl nz na pe nc
cs=0023  ss=002b  ds=002b  es=002b  fs=0053  gs=002b             efl=00010206
tvnviewer+0x6d1f0:
0015d1f0 8b08            mov     ecx,dword ptr [eax]  ds:002b:41414141=????????
0:005> g
(4a30.5f08): Access violation - code c0000005 (first chance)
First chance exceptions are reported before any exception handling.
This exception may be expected and handled.
eax=41414141 ebx=0019860c ecx=02a9e8a8 edx=00000005 esi=755ddf20 edi=03567150
eip=41414141 esp=02a9e8b0 ebp=02a9e8bc iopl=0         nv up ei pl nz na pe nc
cs=0023  ss=002b  ds=002b  es=002b  fs=0053  gs=002b             efl=00010206
41414141 ??              ???
0:005> u
41414141 ??              ???
     ^ Memory access error in 'u'
```

0:005>

Use a debugger to identify root causes and guide exploitation.

Ln 0, Col 0 | Sys 0:<Local> | Proc 000:4a30 | Thrd 005:5f08 | ASM | OVR | CAPS | NUM

Type here to search

33°C Light rain ENG 2:01 pm 23/7/2021

C:\Users\Eugene\Desktop\tvnviewer.exe - WinDbg:10.0.19041.685 X86

File Edit View Debug Window Help

Command

```
CommandLine: C:\Users\Eugene\Desktop\tvnviewer.exe

************* Path validation summary **************
Response                         Time (ms)     Location
Deferred                                       srv*
Symbol search path is: srv*
Executable search path is:
ModLoad: 000f0000 001bc000   tvnviewer.exe
ModLoad: 77220000 773c3000   ntdll.dll
ModLoad: 755c0000 756b0000   C:\WINDOWS\SysWOW64\KERNEL32.DLL
ModLoad: 75d60000 75f74000   C:\WINDOWS\SysWOW64\KERNELBASE.dll
ModLoad: 76050000 760b3000   C:\WINDOWS\SysWOW64\WS2_32.dll
ModLoad: 76b40000 76bff000   C:\WINDOWS\SysWOW64\RPCRT4.dll
ModLoad: 6b2d0000 6b4e0000   C:\WINDOWS\WinSxS\x86_microsoft.windows.common-controls_6595b64144ccf1df_6.0.19041.1110_none_a8625c1886757984\COMCTL32.dll
ModLoad: 769f0000 76aaf000   C:\WINDOWS\SysWOW64\msvcrt.dll
ModLoad: 75870000 75a06000   C:\WINDOWS\SysWOW64\USER32.dll
ModLoad: 75a10000 75a28000   C:\WINDOWS\SysWOW64\win32u.dll
ModLoad: 750d0000 750f3000   C:\WINDOWS\SysWOW64\GDI32.dll
ModLoad: 756b0000 7578c000   C:\WINDOWS\SysWOW64\gdi32full.dll
ModLoad: 76940000 769ef000   C:\WINDOWS\SysWOW64\COMDLG32.dll
ModLoad: 75b40000 75bbb000   C:\WINDOWS\SysWOW64\msvcp_win.dll
ModLoad: 75240000 754c1000   C:\WINDOWS\SysWOW64\combase.dll
ModLoad: 75bc0000 75ce0000   C:\WINDOWS\SysWOW64\ucrtbase.dll
ModLoad: 00cb0000 00dd0000   C:\WINDOWS\SysWOW64\ucrtbase.dll
ModLoad: 76c00000 76c87000   C:\WINDOWS\SysWOW64\shcore.dll
ModLoad: 761b0000 761f5000   C:\WINDOWS\SysWOW64\SHLWAPI.dll
ModLoad: 76370000 76923000   C:\WINDOWS\SysWOW64\SHELL32.dll
ModLoad: 76ab0000 76b2a000   C:\WINDOWS\SysWOW64\ADVAPI32.dll
ModLoad: 75790000 75805000   C:\WINDOWS\SysWOW64\sechost.dll
ModLoad: 73dc0000 73dc8000   C:\WINDOWS\SysWOW64\VERSION.dll
(4a30.6394): Break instruction exception - code 80000003 (first chance)
eax=00000000 ebx=00000000 ecx=9b620000 edx=00000000 esi=77232044 edi=7723260c
eip=772d1b72 esp=003ef73c ebp=003ef768 iopl=0         nv up ei pl zr na pe nc
cs=0023  ss=002b  ds=002b  es=002b  fs=0053  gs=002b             efl=00000246
ntdll!LdrpDoDebuggerBreak+0x2b:
772d1b72 cc              int     3
```

0:000>

Ln 0, Col 0 | Sys 0:<Local> | Proc 000:4a30 | Thrd 000:6394 | ASM | OVR | CAPS | NUM

Type here to search

33°C Light rain

ENG

2:01 pm
23/7/2021

Disclosure itself is an art.

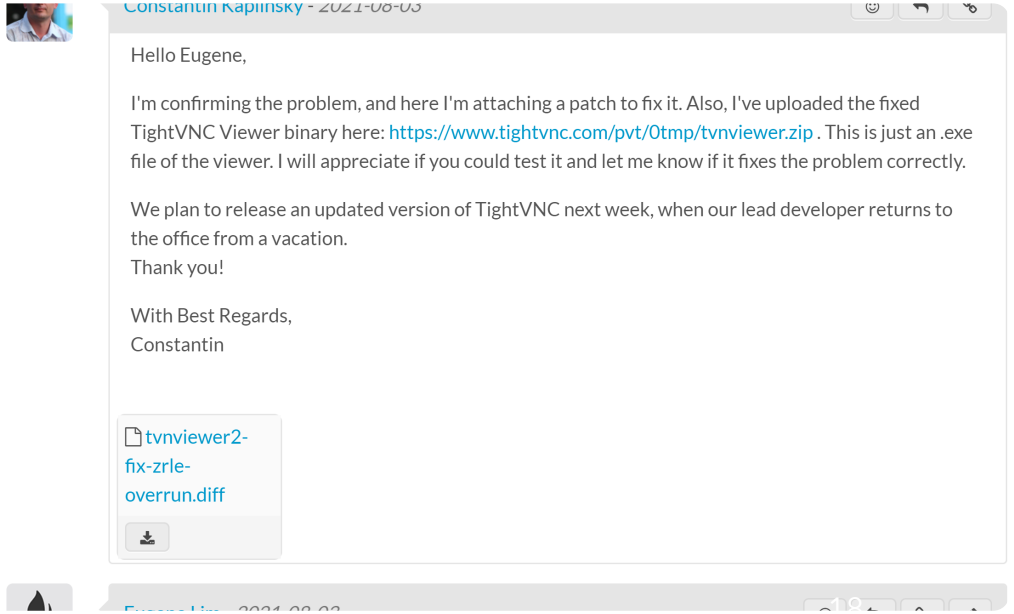
TightVNC: CVE-2021-42785

LibVNC: Bug clash with CrowdStrike two weeks earlier 👀

> Ah wow, looks like I was testing only on the 0.9.13 commits - could I check
> if this was patched because of a vulnerability that was already reported?

It was, by the guys at Crowdstrike.

Best,



Turns out, the real trick is to read a specification, and ask yourself: “If I implemented this spec, what mistakes might I make?”

@retr0id
“BGGP3: Chipping Out”

This workflow provides a good starting point for beginners.


Read specification


Source code review


Write evil server


Run test cases


??? (replace with fuzzing)


Profit

Thank you

Eugene Lim
@spaceraccoonsec
spaceraccoon.dev